APP.4.10 Sicherheit von KI-Systemen

Benutzerdefinierter Baustein nach der Systematik des IT-Grundschutz-Kompendiums (Edition 2023)

1 Beschreibung

1.1 Einleitung

Systeme der künstlichen Intelligenz (KI) und des maschinellen Lernens (ML) sind Bestandteil von Geschäftsprozessen, Fachanwendungen und Standardsoftware. Dazu zählen klassische ML-Modelle für Klassifikation und Prognose ebenso wie generative Modelle, insbesondere große Sprachmodelle (Large Language Models, LLM), die als Assistenzsysteme, in abrufgestützten Anwendungen (Retrieval-Augmented Generation, RAG) oder als KI-Agenten mit Zugriff auf Werkzeuge, Schnittstellen und Daten der Institution eingesetzt werden.

Ein KI-System umfasst neben dem Modell die Trainings-, Feinabstimmungs- und Evaluationsdaten, die Systemanweisungen (System-Prompts), die zur Laufzeit abgerufenen Wissensquellen, die Inferenz-Schnittstellen, die angebundenen Werkzeuge sowie die Werkzeugkette zur Entwicklung und Bereitstellung (ML-Operations, MLOps). Das Verhalten eines KI-Systems wird aus Daten gelernt und zur Laufzeit durch Eingaben beeinflusst. Daraus ergeben sich spezifische Angriffsvektoren über den gesamten Lebenszyklus, von der Erhebung der Trainingsdaten über Training und Bereitstellung bis zum produktiven Betrieb (Inferenz) und zur Aussonderung. Modelle, Datensätze und Erweiterungen werden häufig aus externen Quellen bezogen oder als Dienst genutzt; die Lieferkette ist damit Teil der Angriffsfläche.

1.2 Zielsetzung

Ziel dieses Bausteins ist es, die Vertraulichkeit, Integrität und Verfügbarkeit von KI-Systemen, ihrer Modelle, Daten, Systemanweisungen und Werkzeuganbindungen über den gesamten Lebenszyklus sicherzustellen. Die Anforderungen machen KI-Systeme widerstandsfähiger gegen KI-spezifische Angriffe, begrenzen die Auswirkungen von Fehlverhalten auf den Informationsverbund und gewährleisten eine kontrollierte Integration in die Geschäftsprozesse der Institution.

1.3 Abgrenzung und Modellierung

Der Baustein APP.4.10 ist auf jedes KI-System anzuwenden, in dem KI- oder ML-Modelle entwickelt, trainiert, feinabgestimmt, produktiv betrieben oder über Schnittstellen in Anwendungen eingebunden werden. Dies schließt extern bezogene KI-Dienste und in Standardsoftware integrierte KI-Funktionen ein, soweit die Institution deren Einsatz steuert. Der Baustein ist je KI-System einmal anzuwenden. Bei der Nutzung externer KI-Dienste ist zusätzlich der Baustein OPS.2.2 Cloud-Nutzung beziehungsweise OPS.2.3 Nutzung von Outsourcing anzuwenden.

Der Baustein behandelt nicht die allgemeinen Sicherheitsanforderungen an die zugrunde liegende IT-Infrastruktur; diese sind über die Bausteine der Schichten SYS, NET und INF abzusichern, bei containerbasierten Trainings- und Inferenzumgebungen insbesondere über SYS.1.6 Containerisierung und APP.4.4 Kubernetes. Die Methodik der sicheren Softwareentwicklung regelt CON.8 Software-Entwicklung, Tests und Freigaben regelt OPS.1.1.6 Software-Tests und -Freigaben. Die Absicherung von Web- und API-Schnittstellen als solche regelt APP.3.1 Webanwendungen und Webservices. Die Speicherung von Trainingsdaten und Modellartefakten wird durch SYS.1.8 Speicherlösungen und APP.4.3 Relationale Datenbanksysteme ergänzt. Allgemeine Protokollierung regelt OPS.1.1.5 Protokollierung, Detektion und Vorfallbehandlung regeln DER.1 Detektion von sicherheitsrelevanten Ereignissen und DER.2.1 Behandlung von Sicherheitsvorfällen. Kryptografische Verfahren regelt CON.1 Kryptokonzept, Datensicherung CON.3 Datensicherungskonzept, Löschung CON.6 Löschen und Vernichten, Identitäten und Berechtigungen ORP.4 Identitäts- und Berechtigungsmanagement. Die Verarbeitung personenbezogener Daten regelt CON.2 Datenschutz, die Umsetzung gesetzlicher und regulatorischer Vorgaben für KI-Systeme ORP.5 Compliance Management (Anforderungsmanagement). Ethische Fragestellungen, Fairness und Verzerrungen (Bias) sowie die fachliche Qualität der Modelle außerhalb der Informationssicherheit werden in diesem Baustein nicht behandelt.

2 Gefährdungslage

Für den Baustein APP.4.10 sind folgende spezifische Bedrohungen von besonderer Bedeutung:

Datenvergiftung (Data Poisoning)

Angreifer schleusen fehlerhafte, böswillige oder irreführende Daten in Trainings-, Feinabstimmungs- oder Wissensquellen ein. Das Modell lernt falsche Muster, zeigt systematische Fehler oder enthält eine Hintertür, die im produktiven Betrieb durch ein bestimmtes Auslösemuster aktiviert wird. Bei Systemen, die mit Betriebsdaten nachtrainiert werden oder Wissensquellen aus offenen Kanälen befüllen, genügt es, die Daten an der Quelle zu manipulieren.

Direkte Manipulation von Modellen (Model Poisoning)

Angreifer verändern Modellgewichte, Feinabstimmungsartefakte oder Modelldateien unmittelbar, etwa im Artefakt-Speicher, auf Modell-Plattformen oder während des Transports. Modellformate, die beim Laden Programmcode ausführen, erlauben zusätzlich das Einschleusen von Schadcode in Trainings- und Inferenzumgebungen. Manipulierte Modelle sind durch funktionale Tests allein nicht erkennbar, da sie sich bis zum Auslösen unauffällig verhalten.

Gezielte Umgehung und Manipulation von Modellen (Adversarial Evasion)

Angreifer erstellen zur Laufzeit speziell präparierte Eingabedaten, die das Modell zu einer gezielten Fehlentscheidung verleiten. Diese Manipulationen sind für Menschen oft unauffällig, etwa geringfügig veränderte Bildpixel oder subtil angepasste Textbausteine, stören die maschinelle Klassifizierung jedoch erheblich. Betroffen sind unter anderem Erkennungssysteme für Schadprogramme, Betrug oder unerwünschte Inhalte.

Einschleusen von Anweisungen (Prompt Injection) und Ausgabe-Injektion

Sprachmodelle verarbeiten Anweisungen und Daten im selben Kontext. Angreifer platzieren Anweisungen in Benutzereingaben (direkte Prompt Injection) oder in Inhalten, die das System selbst abruft, etwa in Dokumenten, E-Mails, Webseiten, Tickets oder Werkzeugausgaben (indirekte Prompt Injection). Das Modell führt diese Anweisungen aus, umgeht Nutzungsregeln, gibt vertrauliche Inhalte preis oder löst Aktionen aus. Ausgaben eines Modells können ihrerseits Anweisungen oder Schadcode enthalten, die in nachgelagerten Systemen, Browsern oder weiteren Modellen wirken (Ausgabe-Injektion). Textuelle Leitplanken in Systemanweisungen lassen sich durch solche Angriffe umgehen.

Übermäßige Handlungsbefugnisse von KI-Agenten (Excessive Agency)

KI-Agenten rufen Werkzeuge, Schnittstellen und Programme auf, senden Nachrichten und verändern Daten. Verfügen sie über mehr Berechtigungen, Werkzeuge oder Autonomie als für die Aufgabe erforderlich, führen manipulierte Eingaben, fehlerhafte Schlussfolgerungen oder entführte Ziele (Goal Hijacking) zu Aktionen mit erheblicher Wirkung, etwa zum Löschen von Daten, zum Versand vertraulicher Informationen oder zu Transaktionen. In Mehr-Agenten-Systemen pflanzen sich Fehler und Manipulationen von Agent zu Agent fort und eskalieren Berechtigungen über Vertrauensgrenzen hinweg.

Diebstahl von Modellen und Systemanweisungen (Model Extraction, Hidden Context Exposure)

Durch wiederholte, systematische Abfragen an die Schnittstelle eines Modells rekonstruieren Angreifer dessen Verhalten und erstellen ein funktional äquivalentes Modell. Daneben entlocken Angreifer dem System seine Systemanweisungen, Werkzeugdefinitionen, Richtlinientexte und sonstige nicht für Benutzer bestimmte Kontextinhalte. Die Folgen sind der Verlust geistigen Eigentums und hoher Trainingsinvestitionen sowie die Kenntnis interner Schutzmechanismen, die weitere Angriffe erleichtert.

Offenlegung von Trainingsdaten und vertraulichen Informationen (Model Inversion, Membership Inference, Data Leakage)

Modelle speichern seltene oder häufig wiederholte Beispiele aus ihren Trainingsdaten. Angreifer ermitteln durch gezielte Abfragen, ob bestimmte Datensätze im Training enthalten waren (Membership Inference), oder rekonstruieren Trainingsdaten aus den Ausgaben (Model Inversion). Darüber hinaus geben Modelle vertrauliche Inhalte aus Wissensquellen, aus früheren Sitzungen oder aus dem Gesprächsverlauf an unberechtigte Benutzer weiter, wenn Berechtigungen beim Abruf nicht durchgesetzt werden oder Daten im Modellkontext geteilt werden.

Unsichere Lieferkette von Modellen, Daten und Erweiterungen

Vortrainierte Modelle, Gewichte, Datensätze, Bibliotheken, Erweiterungen (Plugins, Werkzeugdefinitionen, Vorlagen) und Modell-Plattformen werden aus externen Quellen bezogen. Manipulierte oder mit Hintertüren versehene Komponenten, kompromittierte Konten auf Modell-Plattformen, Namensverwechslungen (Typosquatting) und unsichere Serialisierungsformate führen zur Übernahme des gesamten KI-Systems. Herkunft, Lizenz und Integrität der Komponenten sind ohne Verifikation nicht nachvollziehbar.

Unsichere Integration und Orchestrierung der ML-Pipeline

Die Werkzeugkette zur Erstellung und Bereitstellung von KI (MLOps-Pipeline) stellt ein eigenständiges Angriffsziel dar. Eine Kompromittierung des Quellcode-Repositorys, der Trainingsumgebung, der Experimentverwaltung oder des Artefakt-Speichers für Modelle ermöglicht die Manipulation von Daten, Modellen und Konfigurationen. Zugangsdaten und Geheimnisse in Trainingsdaten, Notebooks, Prompts oder Modellartefakten werden über die Pipeline oder über Modellausgaben offengelegt.

Unkontrollierter Ressourcenverbrauch (Denial of Service, Denial of Wallet)

Inferenz ist rechen- und kostenintensiv. Angreifer oder fehlerhafte Automatisierungen erzeugen durch lange Eingaben, rekursive Agentenschleifen, massenhafte Anfragen oder gezielt aufwendige Aufgaben eine Überlast des Modells oder der Infrastruktur. Bei nutzungsabhängig abgerechneten Diensten entstehen hohe Kosten (Denial of Wallet), bis hin zur Abschaltung des Dienstes durch Kontingentgrenzen.

Unzuverlässige Ausgaben und Automatisierungsgläubigkeit

Modelle erzeugen plausible, aber falsche Ausgaben (Konfabulation), erfinden Quellen, Funktionen oder Paketnamen und bewerten Sachverhalte fehlerhaft. Werden Ausgaben ungeprüft in Entscheidungen, Dokumente, Programmcode oder automatisierte Prozesse übernommen, entstehen Integritätsverluste, Fehlentscheidungen und Schwachstellen. Benutzer neigen dazu, Ausgaben eines Systems als geprüft anzusehen und eigene Kontrollen zu unterlassen.

Modelldrift und Verfall von Schutzmaßnahmen im Betrieb

Die Verteilung der Eingabedaten ändert sich im Betrieb, Modelle werden nachtrainiert, Anbieter tauschen Modellversionen aus, und Angriffstechniken entwickeln sich weiter. Schutzmaßnahmen, die bei Inbetriebnahme wirksam waren, verlieren ihre Wirkung, ohne dass dies ohne Überwachung auffällt. Unangekündigte Modelländerungen bei externen Anbietern verändern das Verhalten produktiver Anwendungen und machen bestandene Sicherheitstests ungültig.

Abhängigkeit von externen KI-Diensten

Ausfall, Abkündigung, Kontingentbegrenzung oder Änderung der Nutzungsbedingungen eines externen KI-Dienstes unterbrechen abhängige Geschäftsprozesse. Daten, die an externe Dienste übermittelt werden, verlassen den Kontrollbereich der Institution und werden ohne vertragliche Regelung für das Training der Anbietermodelle verwendet oder in Protokollen des Anbieters aufbewahrt. Ein kurzfristiger Wechsel des Anbieters scheitert an fehlender Vorbereitung.

Fehlende Nachvollziehbarkeit von Aktionen und Entscheidungen

Ohne Protokollierung von Eingaben, Ausgaben, Werkzeugaufrufen und Modellversionen lassen sich Aktionen von KI-Agenten weder einem Auslöser noch einem Verantwortlichen zuordnen. Sicherheitsvorfälle bleiben unerkannt oder sind nicht rekonstruierbar, Entscheidungen des Modells sind gegenüber Betroffenen und Prüfern nicht erklärbar, und Beteiligte können Handlungen abstreiten.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins APP.4.10 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt. Der Informationssicherheitsbeauftragte (ISB) ist bei strategischen Entscheidungen stets einzubeziehen.

Zuständigkeiten	Rollen
Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Fachverantwortliche, Informationssicherheitsbeauftragter (ISB), Entwickler, Beschaffungsstelle, Tester

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN für den Baustein APP.4.10 vorrangig erfüllt werden.

APP.4.10.A1 Planung des sicheren Einsatzes von KI (B) [ISB]

Es MUSS eine Richtlinie existieren, die die Ziele, Verantwortlichkeiten und grundlegenden Sicherheitsregeln für die Entwicklung, die Beschaffung, den Betrieb und die Nutzung von KI-Systemen in der Institution festlegt. Die Richtlinie MUSS festlegen, welche Informationen welcher Klassifizierung an welche KI-Systeme übermittelt werden dürfen und welche Entscheidungen und Aktionen KI-Systeme ohne Freigabe durch eine Person ausführen dürfen.

APP.4.10.A2 Inventarisierung und Klassifizierung von Trainingsdaten (B) [Fachverantwortliche]

Alle für das Training, die Feinabstimmung und die Evaluation von KI-Modellen verwendeten Datensätze MÜSSEN inventarisiert und entsprechend ihrer Schutzbedürftigkeit klassifiziert werden. Der Zugriff auf diese Daten MUSS restriktiv geregelt sein.

APP.4.10.A3 Grundlegende Absicherung der Modell-Schnittstellen (B)

Der Zugriff auf KI-Modelle, die über Schnittstellen (APIs) bereitgestellt werden, MUSS authentisiert und autorisiert werden. Die Schnittstellen MÜSSEN gegen gängige Web- und API-Angriffe geschützt werden. Jede Nutzung MUSS einem Benutzer oder einer technischen Identität zuordenbar sein.

APP.4.10.A4 Protokollierung von Trainingsläufen, Anfragen und Werkzeugaufrufen (B)

Trainingsläufe MÜSSEN protokolliert werden, um nachvollziehen zu können, welches Modell mit welchen Daten und Parametern trainiert wurde. Sicherheitsrelevante Anfragen an produktive Modell-Schnittstellen sowie alle durch KI-Systeme ausgelösten Werkzeug- und Schnittstellenaufrufe MÜSSEN mit auslösender Identität, Zeitpunkt, Modellversion und Ergebnis protokolliert werden. Protokolldaten, die Ein- oder Ausgaben enthalten, MÜSSEN entsprechend der Klassifizierung der verarbeiteten Informationen geschützt werden.

APP.4.10.A5 Nutzung vertrauenswürdiger Modellquellen (B)

Ungeprüfte externe KI-Modelle, Gewichte, Datensätze und Erweiterungen aus unzuverlässigen Quellen DÜRFEN NICHT in produktive Systeme übernommen werden. Herkunft und Integrität externer Komponenten MÜSSEN vor

der Integration verifiziert werden. Modelldateien in Formaten, die beim Laden Programmcode ausführen können, DÜRFEN NICHT aus nicht vertrauenswürdigen Quellen geladen werden.

APP.4.10.A15 Inventarisierung der KI-Systeme und ihrer Komponenten (B) [ISB]

Alle KI-Systeme der Institution, einschließlich genutzter externer KI-Dienste und in Standardsoftware aktivierter KI-Funktionen, MÜSSEN inventarisiert werden. Für jedes KI-System MÜSSEN die eingesetzten Modelle mit Version, die Datenquellen, die Systemanweisungen, die angebundenen Werkzeuge und Schnittstellen, der Einsatzzweck sowie die verantwortlichen Rollen dokumentiert sein. Das Inventar MUSS bei Änderungen aktualisiert werden.

APP.4.10.A16 Behandlung von Eingaben und Kontextinhalten als nicht vertrauenswürdig (B) [Entwickler]

Alle Inhalte, die in den Verarbeitungskontext eines Modells gelangen, einschließlich Benutzereingaben, abgerufener Dokumente, Webinhalte, E-Mails, Werkzeugausgaben und Ausgaben anderer Modelle, MÜSSEN als nicht vertrauenswürdige Daten behandelt werden. Sicherheitsentscheidungen wie Authentisierung, Autorisierung und Freigaben DÜRFEN NICHT ausschließlich durch Anweisungen im Modellkontext durchgesetzt werden; sie MÜSSEN außerhalb des Modells technisch erzwungen werden.

APP.4.10.A17 Begrenzung der Handlungsmöglichkeiten von KI-Systemen (B)

KI-Systeme, die Aktionen auslösen können, insbesondere Werkzeug- und Schnittstellenaufrufe, Codeausführung oder den Versand von Nachrichten, MÜSSEN mit eigener technischer Identität und den für die Aufgabe minimal erforderlichen Berechtigungen betrieben werden. Sie DÜRFEN NICHT mit administrativen Berechtigungen oder mit dem vollständigen Berechtigungsumfang der sie nutzenden Benutzer ausgeführt werden. Für jedes KI-System MUSS festgelegt sein, welche Aktionen vor der Ausführung durch eine berechtigte Person freizugeben sind; Aktionen mit erheblicher oder nicht umkehrbarer Wirkung MÜSSEN freigegeben werden.

APP.4.10.A18 Validierung von Modellausgaben vor der Weiterverarbeitung (B) [Entwickler]

Ausgaben von Modellen MÜSSEN vor der Weitergabe an nachgelagerte Systeme, insbesondere an Browser, Datenbanken, Kommandointerpreter, Schnittstellen und weitere Modelle, wie nicht vertrauenswürdige Eingaben validiert, kodiert oder gefiltert werden. Von Modellen erzeugter Programmcode DARF NICHT ungeprüft außerhalb isolierter Umgebungen ausgeführt werden.

APP.4.10.A19 Schutz von Modellen, Gewichten und Systemanweisungen (B)

Trainierte Modelle, Gewichte, Feinabstimmungsartefakte und Systemanweisungen MÜSSEN als schützenswerte Informationen klassifiziert und gegen unbefugten Zugriff und unbefugte Veränderung geschützt werden. Der Zugriff auf Modellartefakte MUSS auf die Rollen beschränkt werden, die ihn für Entwicklung, Bereitstellung oder Betrieb benötigen.

APP.4.10.A20 Außerbetriebnahme, Rückfall und Behandlung von Sicherheitsvorfällen (B)

Es MUSS sichergestellt sein, dass ein KI-System kurzfristig außer Betrieb genommen, von Werkzeugen und Wissensquellen getrennt oder auf eine freigegebene Vorversion von Modell und Systemanweisungen zurückgesetzt werden kann. KI-spezifische Sicherheitsvorfälle, insbesondere erfolgreiche Prompt Injection, Abfluss vertraulicher Informationen über Ausgaben und unerwünschte Aktionen von KI-Agenten, MÜSSEN in die Behandlung von Sicherheitsvorfällen der Institution einbezogen werden.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik für den Baustein APP.4.10. Sie SOLLTEN grundsätzlich erfüllt werden.

APP.4.10.A6 Sicherstellung der Integrität von Trainingsdaten (S)

Es SOLLTEN technische und organisatorische Maßnahmen ergriffen werden, um die Integrität der Trainings- und Feinabstimmungsdaten zu schützen. Dies umfasst die Überprüfung der Datenquellen, die Nutzung

kryptografischer Prüfsummen, die Prüfung neuer Daten auf Auffälligkeiten vor der Aufnahme sowie die Absicherung der Datenspeicher gegen unautorisierte Veränderungen.

APP.4.10.A7 Absicherung der ML-Pipeline (S)

Der gesamte Lebenszyklus eines Modells SOLLTE durch eine abgesicherte MLOps-Pipeline verwaltet werden. Dies umfasst die Härtung von Code-Repositories, isolierte Trainingsumgebungen ohne Zugriff auf produktive Systeme und geschützte Artefakt-Speicher. Zugangsdaten und andere Geheimnisse SOLLTEN NICHT in Trainingsdaten, Notebooks, Systemanweisungen oder Modellartefakten enthalten sein; sie SOLLTEN außerhalb des Modells verwaltet werden.

APP.4.10.A8 Implementierung von Abwehrmaßnahmen gegen Adversarial Attacks (S) [Entwickler]

Es SOLLTEN robuste Programmierpraktiken und Techniken zur Validierung sowie Bereinigung von Eingabedaten eingesetzt werden, um die Wirksamkeit einfacher Adversarial Attacks (Umgehungsangriffe) einzudämmen.

APP.4.10.A9 Versionierung und Herkunftsverfolgung von Daten, Modellen und Systemanweisungen (S)

Es SOLLTE ein System zur Versionierung von Datensätzen, Modellen, Systemanweisungen und Werkzeugdefinitionen etabliert werden. Es SOLLTE jederzeit nachvollziehbar sein, welche exakte Version eines Modells mit welcher Datenversion trainiert wurde und welche Version von Modell, Systemanweisungen und Werkzeugdefinitionen zu einem Zeitpunkt produktiv war (Data and Model Provenance).

APP.4.10.A10 Überwachung des Modellverhaltens im produktiven Betrieb (S)

Die Vorhersagen, Ausgaben und Aktionen des KI-Systems im produktiven Betrieb SOLLTEN kontinuierlich überwacht werden, um Abweichungen vom erwarteten Verhalten (Model Drift) oder Anomalien, die auf Angriffe hindeuten, frühzeitig zu erkennen. Dazu SOLLTEN auffällige Eingabemuster, Werkzeugaufrufe außerhalb des erwarteten Umfangs, ungewöhnliche Ausgabeinhalte sowie Abweichungen bei Anfragevolumen und Kosten ausgewertet und an die Detektion sicherheitsrelevanter Ereignisse gemeldet werden.

APP.4.10.A21 Bedrohungsmodellierung für KI-Systeme (S) [Fachverantwortliche]

Vor der Inbetriebnahme eines KI-Systems und bei wesentlichen Änderungen SOLLTE eine Bedrohungsanalyse durchgeführt werden, die Daten, Training, Modell, Inferenz-Schnittstellen, Wissensquellen, Werkzeuganbindungen und Lieferkette umfasst. Die identifizierten Bedrohungen SOLLTEN in Sicherheitsanforderungen und Testfälle überführt und dokumentiert werden.

APP.4.10.A22 Sichere Beschaffung und Nutzung externer KI-Dienste (S) [Beschaffungsstelle]

Vor der Nutzung externer KI-Dienste und extern betriebener Modelle SOLLTEN mit dem Anbieter vertraglich geregelt werden: der Ausschluss der Nutzung übermittelter Daten für das Training von Anbietermodellen, Umfang und Aufbewahrungsdauer der anbieterseitigen Protokollierung, die Meldung von Sicherheitsvorfällen, die vorherige Ankündigung von Modelländerungen und Abkündigungen sowie der Zugriff der Institution auf die sie betreffenden Protokolle. Sicherheitsnachweise des Anbieters SOLLTEN eingefordert und bewertet werden.

APP.4.10.A23 Absicherung von Wissensquellen für abrufgestützte Generierung (S)

Bei Systemen, die zur Laufzeit Inhalte aus Wissensquellen abrufen (RAG), SOLLTEN die Zugriffsberechtigungen der Quelldokumente zum Zeitpunkt des Abrufs für den anfragenden Benutzer durchgesetzt werden. Die Aufnahme von Inhalten in Wissensquellen und Vektorindizes SOLLTE auf freigegebene Quellen beschränkt und protokolliert werden; neue Inhalte SOLLTEN vor der Aufnahme auf eingebettete Anweisungen geprüft werden. Die Integrität der Indizes SOLLTE geschützt werden.

APP.4.10.A24 Absicherung von Werkzeugen und Schnittstellen für KI-Agenten (S) [Entwickler]

Werkzeuge, die ein KI-System aufrufen kann, SOLLTEN über eine Positivliste freigegeben und auf den Einsatzzweck beschränkt werden. Parameter von Werkzeugaufrufen SOLLTEN gegen ein festgelegtes Schema validiert werden. Codeausführung durch KI-Systeme SOLLTE ausschließlich in isolierten Umgebungen ohne Zugriff auf produktive Daten und Netze erfolgen. Zugangsdaten für Werkzeuge SOLLTEN NICHT im Modellkontext verfügbar sein.

APP.4.10.A25 Begrenzung des Ressourcenverbrauchs (S)

Für KI-Systeme SOLLTEN Anfragelimits und Kontingente je Benutzer und Anwendung, maximale Längen von Ein- und Ausgaben, Zeitlimits je Anfrage sowie eine Obergrenze für aufeinanderfolgende Agentenschritte festgelegt und technisch durchgesetzt werden. Bei nutzungsabhängig abgerechneten Diensten SOLLTEN Kostengrenzen mit Alarmierung eingerichtet werden.

APP.4.10.A26 Sicherheitstests vor Inbetriebnahme und nach Änderungen (S) [Tester]

KI-Systeme SOLLTEN vor der Inbetriebnahme auf direkte und indirekte Prompt Injection, Offenlegung von Systemanweisungen und vertraulichen Informationen, Umgehung von Nutzungsregeln und Missbrauch angebundener Werkzeuge getestet werden. Die Tests SOLLTEN automatisiert als Regressionstests bei jeder Änderung von Modell, Systemanweisungen, Wissensquellen oder Werkzeugen wiederholt werden.

APP.4.10.A27 Änderungsmanagement für Modelle und Systemanweisungen (S)

Änderungen an Modellen, einschließlich anbieterseitiger Versionswechsel, an Systemanweisungen und an Werkzeugdefinitionen SOLLTEN dem Änderungsmanagement der Institution unterliegen. Produktiv genutzte Modellversionen SOLLTEN explizit festgelegt werden. Ein Versionswechsel SOLLTE vor der produktiven Nutzung getestet und freigegeben werden.

APP.4.10.A28 Sensibilisierung der Benutzer von KI-Systemen (S) [ISB]

Benutzer von KI-Systemen SOLLTEN darüber geschult werden, welche Informationen in welche KI-Systeme eingegeben werden dürfen, dass Ausgaben vor der Verwendung zu prüfen sind und wie auffälliges Verhalten eines KI-Systems zu melden ist.

APP.4.10.A29 Umgang mit Ausgaben von KI-Systemen (S) [Fachverantwortliche]

Für jedes KI-System SOLLTE festgelegt werden, welche Ausgaben ohne Prüfung durch eine Person verwendet werden dürfen. Ausgaben, die in Entscheidungen mit Auswirkungen auf Personen, Vermögenswerte oder die Sicherheit des Informationsverbunds einfließen, SOLLTEN vor der Verwendung geprüft werden. Von KI-Systemen erzeugte Inhalte SOLLTEN als solche gekennzeichnet werden.

APP.4.10.A30 Aussonderung von KI-Systemen und Modellen (S)

Bei der Außerbetriebnahme eines KI-Systems SOLLTEN Modellartefakte, Feinabstimmungsdaten, Vektorindizes und Protokolle mit Ein- und Ausgaben gemäß dem Löschkonzept der Institution gelöscht werden. Beim Anbieter gespeicherte Daten SOLLTEN gelöscht und die Löschung bestätigt werden. Technische Identitäten und Zugangsdaten des KI-Systems SOLLTEN entzogen werden.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Im Folgenden sind für den Baustein APP.4.10 exemplarische Vorschläge für Anforderungen aufgeführt, die über das dem Stand der Technik entsprechende Schutzniveau hinausgehen und bei erhöhtem Schutzbedarf in Betracht gezogen werden SOLLTEN. Die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

APP.4.10.A11 Schutzmaßnahmen gegen Modell-Extraktion (H)

Der Zugriff auf die Modell-Schnittstelle SOLLTE automatisiert analysiert werden, um verdächtige Abfragemuster zu erkennen, die auf einen Extraktionsangriff hindeuten. Maßnahmen wie dynamisches Rate-Limiting oder das Hinzufügen von Wasserzeichen zu den Modellausgaben SOLLTEN implementiert werden. (C, I)

APP.4.10.A12 Durchführung von Adversarial-Robustness-Tests (H) [Entwickler]

KI-Modelle SOLLTEN proaktiv mit spezialisierten Frameworks auf ihre Widerstandsfähigkeit gegen Adversarial Attacks getestet werden. Die Ergebnisse SOLLTEN genutzt werden, um die Modelle durch robuste Trainingstechniken (z. B. Adversarial Training) zu härten. (I, A)

APP.4.10.A13 Einsatz von Techniken zur Erklärbarkeit und Interpretierbarkeit (XAI) (H)

Es SOLLTEN Techniken aus dem Bereich der Explainable AI (XAI) eingesetzt werden, um die Entscheidungen des Modells nachvollziehbar zu machen. (I)

APP.4.10.A14 Nutzung von Privacy-Enhancing Technologies (PETs) (H)

Beim Training mit sensiblen, insbesondere personenbezogenen Daten SOLLTEN kryptografische und statistische Verfahren (z. B. Differential Privacy, Federated Learning) eingesetzt werden, um das Risiko von Data Leakage und Model Inversion zu minimieren. (C)

APP.4.10.A31 Unabhängiges Red Teaming von KI-Systemen (H) [Tester]

KI-Systeme SOLLTEN regelmäßig und nach wesentlichen Änderungen durch Stellen, die von der Entwicklung unabhängig sind, angriffsorientiert geprüft werden. Die Prüfszenarien SOLLTEN aus der Bedrohungsmodellierung abgeleitet werden und Angriffe über Eingaben, Wissensquellen, Werkzeuge und Lieferkette umfassen. Die Behebung der Befunde SOLLTE nachverfolgt werden. (C, I, A)

APP.4.10.A32 Kryptografische Absicherung der Modellherkunft (H)

Modellartefakte, Datensätze und Systemanweisungen SOLLTEN bei der Freigabe signiert werden. Die Signaturen SOLLTEN vor dem Laden in Trainings- und Inferenzumgebungen geprüft werden. Für jedes KI-System SOLLTE ein Verzeichnis der enthaltenen Modelle, Datensätze, Bibliotheken und Erweiterungen mit Version und Herkunft geführt werden. (I)

APP.4.10.A33 Isolation und Überwachung von Agentensystemen (H)

Jeder KI-Agent SOLLTE in einer eigenen isolierten Ausführungsumgebung mit eigener technischer Identität betrieben werden. Die Kommunikation zwischen Agenten SOLLTE authentisiert, autorisiert und protokolliert werden. Berechtigungen SOLLTEN NICHT zwischen Agenten weitergegeben werden können. Für Agentenketten SOLLTEN Abbruchkriterien festgelegt und technisch erzwungen werden. (I, A)

APP.4.10.A34 Erkennung und Blockierung von Angriffen an Ein- und Ausgaben (H)

Ein- und Ausgaben von KI-Systemen SOLLTEN zur Laufzeit auf Anweisungsmuster, Offenlegung vertraulicher Informationen und Verstöße gegen Nutzungsregeln geprüft und bei Treffern blockiert werden. Die Prüfkomponenten SOLLTEN getrennt vom geschützten Modell betrieben werden. Die Grenzen der Erkennung SOLLTEN dokumentiert und Treffer an die Detektion sicherheitsrelevanter Ereignisse gemeldet werden. (C, I)

APP.4.10.A35 Vertrauliche Verarbeitung von Modellen und Daten (H)

Training und Inferenz mit Informationen hohen Schutzbedarfs SOLLTEN in Umgebungen erfolgen, die Daten und Modelle auch zur Laufzeit gegen Zugriff des Betreibers oder Dienstleisters schützen, oder ausschließlich in der eigenen Infrastruktur der Institution. (C)

APP.4.10.A36 Trennung von KI-Systemen nach Schutzbedarf (H)

KI-Systeme, die Informationen unterschiedlichen Schutzbedarfs oder unterschiedlicher Benutzergruppen verarbeiten, SOLLTEN getrennt betrieben werden. Modellinstanzen, Wissensquellen und persistente Agentenspeicher SOLLTEN NICHT über Vertrauensgrenzen hinweg gemeinsam genutzt werden. (C, I)

APP.4.10.A37 Notfallvorsorge für KI-Systeme (H)

Für KI-Systeme mit Verfügbarkeitsanforderungen SOLLTE ein Rückfall auf alternative Modelle, Anbieter oder manuelle Prozesse vorbereitet und regelmäßig getestet werden. Modellartefakte, Systemanweisungen, Werkzeugdefinitionen und Vektorindizes SOLLTEN in die Datensicherung einbezogen werden. (A)

4 Weiterführende Informationen

4.1 Wissenswertes

Die Gefährdungslage dieses Bausteins orientiert sich an den Bedrohungskategorien der ISO/IEC 27090:2026 „Cybersecurity – Artificial intelligence (AI) – Addressing security threats and compromises to AI systems" (JTC 1/SC 27) sowie an den Schwachstellenklassen der OWASP-Listen. Die Lebenszyklusgliederung der Anforderungen folgt ISO/IEC 5338:2023 „AI system life cycle processes" und ETSI TS 104 223 „Securing Artificial Intelligence (SAI); Baseline Cyber Security Requirements for AI Models and Systems". Die Anforderungen sind eigenständig formuliert; die genannten Dokumente dienen als Stand der Technik für die Umsetzung und Prüfung.

Für die Einbettung in ein Managementsystem stellt ISO/IEC 42001:2023 „Artificial intelligence – Management system" Anforderungen an ein KI-Managementsystem bereit; ISO/IEC 23894:2023 beschreibt das KI-Risikomanagement, ISO/IEC 42005:2025 die Folgenabschätzung für KI-Systeme. ISO/IEC 27091 (Final Draft) ergänzt ISO/IEC 27090 um den Schutz der Privatsphäre in KI-Systemen. ISO/IEC TR 27563:2023 sammelt Sicherheits- und Datenschutz-Anwendungsfälle für KI.

Auf europäischer Ebene erarbeitet CEN/CENELEC JTC 21 im Auftrag der Europäischen Kommission harmonisierte Normen zur KI-Verordnung, darunter prEN 18282 „Cybersecurity for AI systems" und EN 18286:2026 zum Qualitätsmanagementsystem für KI-Systeme. Die Zuordnung dieses Bausteins zu diesen Normen ist bei deren Veröffentlichung zu prüfen.

Das BSI stellt mit dem Katalog „Artificial Intelligence Cloud Service Compliance Criteria Catalogue (AIC4)" prüfbare Kriterien für den sicheren Einsatz von KI-Diensten in Cloud-Umgebungen bereit. Die Veröffentlichung „Generative KI-Modelle – Chancen und Risiken für Industrie und Behörden" des BSI beschreibt Risiken und Gegenmaßnahmen für große Sprachmodelle. Die gemeinsam mit internationalen Partnerbehörden veröffentlichten Leitlinien „Deploying AI Systems Securely" (2024) und „AI Data Security" (2025) geben Empfehlungen für Betrieb und Datenhaltung; die gemeinsame Leitlinie der Five-Eyes-Behörden zu KI-Agenten (Mai 2026) behandelt Berechtigungen, Konfiguration, Verhalten, Struktur und Verantwortlichkeit von Agentensystemen.

Das US-amerikanische NIST stellt mit dem „AI Risk Management Framework 1.0" und dem Profil „NIST AI 600-1" für generative KI ein Risikorahmenwerk bereit; die „Control Overlays for Securing AI Systems" (COSAiS) ordnen Kontrollen aus NIST SP 800-53 den Anwendungsfällen generative KI, prädiktive KI, Einzel- und Mehr-Agenten-Systeme sowie Modellentwicklung zu.

Für die technische Bewertung und Modellierung von Angriffen auf KI-Systeme ist das Framework „MITRE ATLAS" (Adversarial Threat Landscape for AI Systems) eine etablierte Referenz. Praxisnahe Hilfestellungen bieten die Listen des OWASP-Projekts, insbesondere die „OWASP Top 10 for LLM Applications" (Ausgabe 2025/2026), die „OWASP Top 10 for Agentic Applications" (2025) sowie die „OWASP Machine Learning Security Top 10" für klassische ML-Systeme. Die ENISA-Veröffentlichungen „Securing Machine Learning Algorithms" (2021) und „Multilayer Framework for Good Cybersecurity Practices for AI" (2023) ordnen Schutzmaßnahmen den Schichten eines KI-Systems zu.

Kreuzreferenztabelle zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein APP.4.10 von Bedeutung:

- G 0.11 Ausfall oder Störung von Dienstleistungsunternehmen
- G 0.14 Ausspähen von Informationen (Spionage)
- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.19 Offenlegung schützenswerter Informationen
- G 0.20 Informationen oder Produkte aus unzuverlässiger Quelle
- G 0.21 Manipulation von Hard- oder Software

- G 0.22 Manipulation von Informationen
- G 0.23 Unbefugtes Eindringen in IT-Systeme
- G 0.26 Fehlfunktion von Geräten oder Systemen
- G 0.27 Ressourcenmangel
- G 0.28 Software-Schwachstellen oder -Fehler
- G 0.30 Unberechtigte Nutzung oder Administration von Geräten und Systemen
- G 0.31 Fehlerhafte Nutzung oder Administration von Geräten und Systemen
- G 0.32 Missbrauch von Berechtigungen
- G 0.37 Abstreiten von Handlungen
- G 0.38 Missbrauch personenbezogener Daten
- G 0.39 Schadprogramme
- G 0.40 Verhinderung von Diensten (Denial of Service)
- G 0.45 Datenverlust
- G 0.46 Integritätsverlust schützenswerter Informationen

Kreuzreferenztabelle: Anforderungen und elementare Gefährdungen

Anforderung	G 0.11	G 0.14	G 0.18	G 0.19	G 0.20	G 0.21	G 0.22	G 0.23	G 0.26	G 0.27	G 0.28	G 0.30	G 0.31	G 0.32	G 0.37	G 0.38	G 0.39	G 0.40	G 0.45	G 0.46
APP.4.10.A1 (B)			X	X									X							
APP.4.10.A2 (B)		X		X												X				
APP.4.10.A3 (B)		X						X				X								
APP.4.10.A4 (B)							X								X					X
APP.4.10.A5 (B)					X	X											X			
APP.4.10.A15 (B)			X	X									X							
APP.4.10.A16 (B)							X	X						X						X
APP.4.10.A17 (B)												X		X						X
APP.4.10.A18 (B)								X			X						X			
APP.4.10.A19 (B)		X		X		X														
APP.4.10.A20 (B)									X									X		X
APP.4.10.A6 (S)						X	X													X
APP.4.10.A7 (S)						X		X			X									
APP.4.10.A8 (S)							X		X											
APP.4.10.A9 (S)					X		X								X					
APP.4.10.A10 (S)							X		X			X								
APP.4.10.A21 (S)			X								X									
APP.4.10.A22 (S)	X			X	X															
APP.4.10.A23 (S)				X			X							X						
APP.4.10.A24 (S)								X			X			X						
APP.4.10.A25 (S)										X								X		
APP.4.10.A26 (S)				X			X				X									
APP.4.10.A27 (S)			X						X				X							
APP.4.10.A28 (S)				X									X							
APP.4.10.A29 (S)									X				X							X
APP.4.10.A30 (S)				X								X				X				
APP.4.10.A11 (H)		X		X																
APP.4.10.A12 (H)							X		X											
APP.4.10.A13 (H)									X				X							
APP.4.10.A14 (H)				X												X				
APP.4.10.A31 (H)							X	X			X									
APP.4.10.A32 (H)					X	X														X
APP.4.10.A33 (H)								X						X	X					
APP.4.10.A34 (H)				X			X	X												
APP.4.10.A35 (H)		X		X																
APP.4.10.A36 (H)				X										X						
APP.4.10.A37 (H)	X																		X	